

Actividad 01. Análisis y planificación del pentest

Laura Elizabeth Sierra Bolaños

Hacker Women Council . Ethical Hacking

Objetivo del pentest:

1. Identificar vulnerabilidades de seguridad en la aplicación web, especialmente aquellas que puedan permitir el acceso o exposición de información de otros usuarios. Verificar si un usuario puede acceder o visualizar información perteneciente a otra cuenta.
2. Evaluar el impacto y nivel de riesgo de las vulnerabilidades encontradas, determinando qué información o funcionalidades podrían verse comprometidas. Identificando vulnerabilidades en la autenticación, autorización y control de acceso de la aplicación web.
3. Proponer medidas de seguridad para corregir las vulnerabilidades detectadas y reducir los riesgos, fortaleciendo la protección de los usuarios y de la información de Aurora Market.

Alcance.

Si se evaluara:

- Aplicación web.
- Mecanismos de autenticación y autorización.
- Gestión de usuarios y control de acceso.
- Información y funcionalidades relacionadas con productos, carritos y pedidos.
- Base de datos, únicamente en lo necesario para evaluar la seguridad de la aplicación.

Fuera de alcance:

- Redes sociales de Aurora Market.
- Equipos y dispositivos de los empleados.
- Sistemas o aplicaciones de terceros que no formen parte de Aurora Market.
- Proveedores y servicios externos.
- Infraestructura física de la empresa.
- Ataques de denegación de servicio (DoS/DDoS) o cualquier prueba que pueda interrumpir la disponibilidad de la plataforma.
- Información real de los clientes, evitando modificar, eliminar o exponer datos reales.

Autorización y condiciones.

Permisos requeridos.

- Autorización escrita del responsable de Aurora Market para realizar las pruebas de seguridad.
- Permiso para evaluar únicamente los sistemas, aplicaciones, redes y equipos incluidos en el alcance.
- Autorización para realizar pruebas de vulnerabilidades y, cuando corresponda, explotación controlada.
- Acceso a las cuentas, sistemas o ambientes de prueba necesarios para realizar la evaluación.

Condiciones acordadas.

- Las pruebas se realizarán únicamente dentro del alcance y horario previamente establecido.
- No se realizarán actividades que puedan provocar pérdida de información, interrupciones graves o daños en los sistemas.
- No se accederá, modificará ni divulgará información que no sea necesaria para la evaluación.
- Si se detecta una vulnerabilidad crítica o se presenta algún incidente durante las pruebas, se notificará inmediatamente al responsable.
- Los resultados y evidencias obtenidos durante la evaluación serán tratados de manera confidencial.

Tipo de pentest: Caja negra (Black Box)

La evaluación se realizará como una prueba de **caja negra**, en la que el equipo de seguridad tendrá información limitada sobre la infraestructura de Aurora Market. Esto permite simular el comportamiento de un atacante externo que intenta identificar y explotar vulnerabilidades sin contar inicialmente con información interna del sistema.

Justificación: Este tipo de prueba permite evaluar qué tan expuestos están los sistemas de Aurora Market frente a un atacante externo y qué información podría obtener sin autorización.

Planificación.

1. **Objetivos:** Identificar vulnerabilidades de seguridad, evaluar los riesgos existentes y determinar posibles formas de acceso no autorizado a los sistemas incluidos en la evaluación.
2. **Alcance:** Se evaluarán únicamente los sistemas, aplicaciones, redes y servicios previamente definidos dentro del alcance. Quedarán excluidos los sistemas y recursos que no hayan sido autorizados.
3. **Permisos y condiciones:** Antes de comenzar se contará con autorización escrita de Aurora Market. Se establecerán las condiciones de las pruebas, horarios permitidos, límites de las actividades y procedimientos para reportar cualquier incidente.
4. **Metodología a utilizar:** Se seguirá una metodología de pentesting por etapas: reconocimiento, recopilación de información, análisis de vulnerabilidades, explotación controlada y elaboración del informe final.
5. **Recopilación de información previa:** Se reunirá la información disponible sobre los sistemas autorizados, como dominios, direcciones IP, aplicaciones, servicios y tecnologías utilizadas, sin realizar actividades fuera del alcance establecido.
6. **Recursos necesarios:** Se utilizarán equipos de cómputo, conexión de red y herramientas de seguridad autorizadas, como Nmap, OWASP ZAP y otras herramientas necesarias para la evaluación.
7. **Programación del pentest:** Se establecerán las fechas y horarios de cada etapa, procurando realizar las pruebas en periodos que reduzcan el impacto sobre las operaciones de Aurora Market.

Fases del pentest.

Reconocimiento: Se recopiló información sobre los sistemas autorizados de Aurora Market, como dominios, direcciones IP, servicios y tecnologías utilizadas, para identificar posibles puntos de entrada.

Análisis de vulnerabilidades: Se realizarán pruebas para detectar vulnerabilidades, configuraciones inseguras y debilidades en los sistemas incluidos en el alcance.

Explotación: Se comprobará de manera controlada si las vulnerabilidades identificadas pueden ser aprovechadas por un atacante, evitando causar daños o interrupciones en los sistemas.

Post-explotación: Se determinará el impacto que podría tener una vulnerabilidad explotada, evaluando hasta dónde podría llegar un atacante y qué información o recursos podría comprometerse. Las actividades se mantendrán dentro de los permisos establecidos.

Informe: Se documentan las vulnerabilidades encontradas, evidencias, nivel de riesgo, impacto y recomendaciones para corregirlas y mejorar la seguridad de Aurora Market.

Investigación.

Investigación: OSINT

OSINT (Open Source Intelligence) es una técnica de recopilación y análisis de información obtenida de fuentes públicas. Durante esta etapa se pueden utilizar herramientas y técnicas como Google Dorks, registros DNS, Traceroute, Shodan y Nmap, siempre dentro del alcance y con autorización.

¿Por qué sería útil para este proyecto?

OSINT sería útil para la evaluación de seguridad de Aurora Market porque permite recopilar información pública sobre la infraestructura de la organización antes de realizar pruebas más profundas. Por ejemplo, se pueden identificar dominios, registros DNS, direcciones IP, servicios y posibles puertos expuestos. Esta información ayuda a conocer la superficie de ataque y a planificar de manera más adecuada las siguientes fases del pentest.

También es importante diferenciar OSINT de doxing: OSINT busca recopilar información de fuentes públicas con un propósito legítimo, mientras que el doxing consiste en recopilar y divulgar información personal identificable de una persona, generalmente de manera invasiva o maliciosa.